

SESIONES (SESSIONS)

COOKIES

JSON WEB TOKENS (JWT)

Definición

Guardan la información del usuario en el servidor durante el tiempo que permanece autenticado.

Son pequeños archivos que el navegador almacena para guardar información del usuario.

Son tokens firmados digitalmente que permiten autenticar e identificar a un usuario sin guardar sesiones en el servidor.

¿Dónde se almacena la información?

En el servidor. El navegador solo guarda el identificador de la sesión.

En el navegador del usuario.

En el cliente (LocalStorage, sessionStorage o Cookies).

¿Quién administra la información?

El servidor administra toda la información de la sesión.

El navegador almacena la cookie y el servidor puede leerla o modificarla.

El cliente almacena el token y el servidor verifica que sea válido.

Nivel de seguridad

Alto, ya que los datos importantes permanecen en el servidor.

Medio, porque pueden ser robadas si no están protegidas.

Alto, siempre que se utilicen HTTPS y firmas seguras.

Persistencia de la información

Dura mientras la sesión esté activa o hasta que expire.

Puede mantenerse incluso después de cerrar el navegador, según su configuración.

Tiene una fecha de expiración definida al crear el token.

Ventajas

Son seguras, fáciles de controlar y permiten cerrar la sesión desde el servidor.

Permiten recordar preferencias y mejorar la experiencia del usuario.

Son rápidas, escalables e ideales para aplicaciones modernas y APIs REST.

Desventajas

Consumen recursos del servidor cuando hay muchos usuarios conectados.

Pueden ser modificadas o robadas si no se protegen correctamente.

Si un atacante obtiene el token, podrá usarlo hasta que expire.

Casos de uso

Sistemas bancarios, plataformas escolares, tiendas en línea y aplicaciones web tradicionales.

Recordar idioma, tema, inicio de sesión o contenido del carrito de compras.

Aplicaciones móviles, microservicios, APIs REST y aplicaciones de una sola página (SPA).

Riesgos de seguridad

Robo o secuestro de sesión (Session Hijacking).

Robo de cookies, ataques XSS y CSRF.

Robo del token y almacenamiento inseguro del mismo.

Medidas de protección

Utilizar HTTPS, regenerar el ID de sesión y establecer tiempos de expiración.

Configurar las cookies con HttpOnly, Secure y SameSite, además de usar HTTPS.

Utilizar HTTPS, establecer una expiración corta, firmar correctamente el token y usar Refresh Tokens cuando sea necesario.

Ejemplos de aplicaciones

Moodle, WordPress y sistemas de banca en línea.

Amazon, Mercado Libre y sitios con opción "Recordarme".

Google, Facebook, aplicaciones móviles y servicios con APIs.

